

Threat Model and Secure Configuration

Application: Student Portal Web Application

Domain: Cyber Security

Objective: Identify realistic security threats and create a prioritized hardening plan.

1. System Overview

The Student Portal allows students to log in, view and update their profile, access academic information, and submit/view academic records.

System Components

Student/User: Accesses the portal through a web browser.

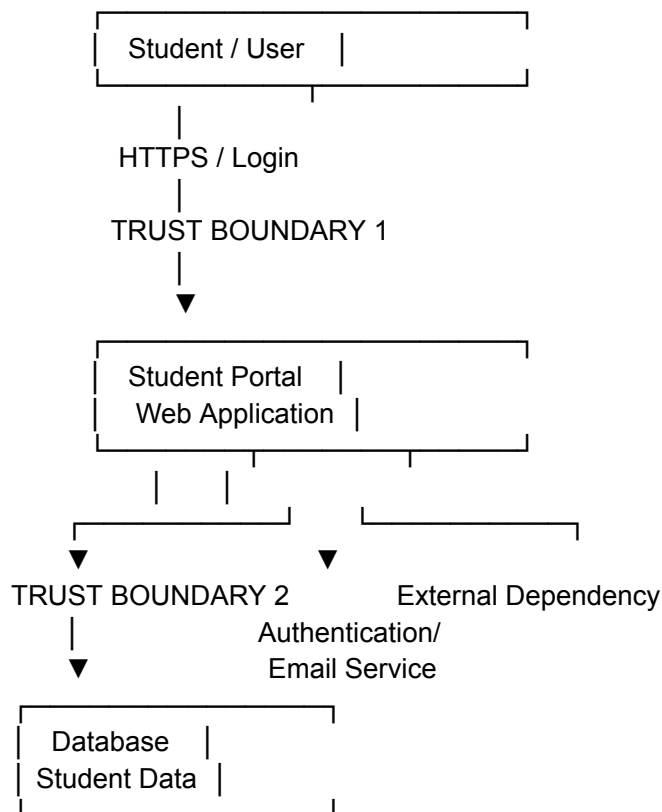
Web Application: Handles authentication, requests and application logic.

Database: Stores student accounts, profiles and academic records.

Authentication Service: Handles user authentication.

Email Service: Used for notifications and account-related communication.

Trust Boundary Diagram



2. Important Assets

Asset

Owner

Importance

Student credentials

Student/Admin

High

Student personal information

Student/University

High

Academic records

University
High
Authentication session
Application
High
Database
University
Critical
Application availability
University
High

3. STRIDE Threat Analysis

STRIDE

Threat

Precondition

Risk

Spoofing

Stolen student credentials used to access an account

Weak/reused password or compromised credentials

High

Tampering

Unauthorized modification of student records

Insufficient authorization checks

High

Repudiation

User denies performing an important action

Insufficient activity logging

Medium

Information Disclosure

Unauthorized access to student information

Poor access control or exposed data

High

Denial of Service

Excessive requests make the portal unavailable

No rate limiting or request controls

Medium

Elevation of Privilege

Student obtains administrator privileges

Broken role-based access control

Critical

4. Risk Prioritization

Threat

Likelihood

Impact

Priority

Elevation of Privilege

Medium

Critical

Critical

Unauthorized record modification

High

High

Critical

Information Disclosure

Medium

High

High

Credential Spoofing

High

High

High

Denial of Service

Medium

High

Medium

Repudiation

Medium

Medium

Medium

5. Hardening Plan

1. Strengthen Authentication

Enforce strong passwords.

Use secure password hashing.

Implement multi-factor authentication where possible.

Apply account lockout/rate limiting for repeated failed logins.

Verification: Test repeated failed logins and confirm that rate limiting/lockout works.

2. Implement Role-Based Access Control

Separate student and administrator permissions.

Verify authorization on every sensitive request.

Prevent students from accessing administrative functions.

Verification: Attempt to access an admin-only function using a student account and confirm access is denied.

3. Protect Student Data

Use HTTPS for communication.

Encrypt sensitive data where appropriate.

Prevent unauthorized database access.

Avoid exposing sensitive information in responses or logs.

Verification: Check application responses and logs for unnecessary sensitive data.

4. Prevent Unauthorized Modification

Validate and authorize all record-update requests.

Use server-side validation.

Ensure users can modify only records they are authorized to modify.

Verification: Test access to another student's record and confirm the request is rejected.

5. Improve Logging and Monitoring

Record authentication failures and important account/record changes.

Do not log passwords, access tokens or unnecessary personal information.

Monitor unusual authentication activity.

Verification: Perform a test login failure and confirm that an appropriate security event is recorded without exposing credentials.

6. Rate Limiting and Availability Protection

Apply rate limits to login and sensitive endpoints.

Monitor unusual request spikes.

Configure appropriate request limits.

Verification: Send repeated test requests in the isolated environment and confirm that excessive requests are restricted.

6. Priority Summary

Critical:

Role/privilege escalation

Unauthorized modification of records

High:

Credential compromise

Information disclosure

Medium:

Denial of service

Repudiation

7. Conclusion

The threat model identified authentication, authorization, data protection, logging and availability as the major security areas of the Student Portal. The highest priority is given to preventing privilege escalation and unauthorized modification of academic records.

Implementing strong authentication, role-based access control, secure data handling, logging and rate limiting can significantly improve the security of the application.